UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

El eslabón más débil: diseño ético de una campaña de Ingeniería social

CNO V – Seguridad Informática

Viernes 06 marzo de 2026

Elisa Alejandra

Arellano

Wratny

177339

Tabla de contenido

Análisis comparativo de plataformas profesionales de simulación de phishing 2
1. Marco teórico y fundamentación técnica 2
1.1 El riesgo humano en ciberseguridad 2
1.2 Métricas clave en simulación de phishing 2
1.3 Enfoques de entrenamiento 3
2. Fichas descriptivas de cada plataforma 3
2.1 Hoxhunt 3
2.2 Proofpoint 4
2.3 KnowBe4 4
2.4 Cofense 4
2.5 Phished 5
2.6 NINJIO 5
2.7 Mimecast 5
2.8 Infosec IQ 6
3. Tabla técnica comparativa 6
4. Análisis crítico comparativo 7
Grupo 1 – IA Adaptativa Avanzada 7
Grupo 2 – Integración empresarial y compliance 7
Grupo 3 – Cultura y engagement 7
Ventajas comparativas 7
Limitaciones generales del mercado 7
5. Consideraciones éticas en la simulación de phishing 8
6. Conclusión comparativa 8
7. Referencias 9

Análisis comparativo de plataformas profesionales de simulación de phishing

Hoxhunt, Proofpoint, KnowBe4, Cofense, Phished, Ninjio, Mimecast, Infosec IQ

1. Marco teórico y fundamentación técnica

1.1 El riesgo humano en ciberseguridad

El phishing sigue siendo uno de los principales vectores de ataque en incidentes de seguridad a nivel mundial. Según reportes de la industria (Verizon DBIR, Proofpoint Threat Reports), el error humano continúa siendo un factor determinante en brechas de seguridad.

La simulación de phishing no tiene como objetivo "castigar" al usuario, sino medir y reducir el riesgo humano mediante:

- Evaluación conductual
- Entrenamiento adaptativo
- Métricas de madurez
- Cultura de reporte temprano

Las plataformas modernas ya no solo miden quién hace clic, sino que aplican analítica conductual, aprendizaje adaptativo y modelos de scoring de riesgo humano.

1.2 Métricas clave en simulación de phishing

Las plataformas analizadas utilizan métricas relativamente estandarizadas, aunque con variaciones metodológicas:

- Click Rate: porcentaje de usuarios que hicieron clic en un enlace simulado.

$$ClickRate = \frac{Usuariosquehicieronclic}{Usuariosquerecibieronelcorreo} * 100$$

- Reporting Rate: porcentaje de usuarios que reportaron el correo sospechoso.

$$ReportingRate = \frac{Usuariosquereportaron}{Usuariosquerecibieronelcorreo} * 100$$

- Failure Rate: usuarios que hicieron clic, ingresaron credenciales o descargaron archivos.

- Risk Score/Human Risk Score: índice compuesto que integra:
    - Historial de clics
    - Reportes
    - Participación en entrenamiento
    - Rol organizacional
    - Exposición al riesgo

1.3 Enfoques de entrenamiento

Las plataformas pueden clasificarse en cuatro enfoques principales:

Enfoque	**Características**
Tradicional basado en campañas	Envío masivo de simulaciones periódicas
Adaptativo basado en IA	Ajusta dificultad según comportamiento
Microlearning contextual	Entrenamiento inmediato tras el error
Cultura de reporte	Incentiva comportamiento proactivo

2. Fichas descriptivas de cada plataforma

2.1 Hoxhunt

Enfoque	**Gamificación + IA adaptativa**
Diferenciador	Entrenamiento automático personalizado basado en comportamiento individual.
Fortalezas: • **Motor de IA adaptativa** • **Gamificación avanzada** • **Enfoque fuerte en reporting rate** • **Integración con Microsoft 365**	
Limitaciones: • **Alto costo comparativo** • **Menor enfoque en compliance formal**	
Contexto ideal	Empresas con cultura organizacional madura y enfoque en transformación conductual.

2.2 Proofpoint

Producto relevante	**Proofpoint Security Awareness Training**
Proofpoint integra simulación de phishing dentro de su ecosistema de protección de correo electrónico.	
Fortalezas: • **Integración con su Gateway de email** • **Threat intelligence real** • **Segmentación por riesgo organizacional**	
Limitaciones: • **Menos enfoque en gamificación** • **Dependencia del ecosistema Proofpoint**	
Contexto ideal	Organizaciones grandes que ya usan Proofpoint somo solución de email security.

2.3 KnowBe4

Uno de los líderes del mercado en awareness training.	
Fortalezas: • **Amplísima biblioteca de contenido** • **PhishER (orquetación de reportes)** • **Human Risk Score**	
Limitaciones: • **Enfoque más tradicional en campañas** • **Puede generar fatiga si no se gestiona bien**	
Contexto ideal	Empresas que requieren cumplimiento normativo (ISO 27001, NIST, PCI-DSS)

2.4 Cofense

Especialista en phishing defense y reporte.	
Fortalezas: • **Enfoque en análisis de correos reportados** • **Plataforma robusta de triage** • **Cultura de "human sensor network"**	
Limitaciones: • **Menor enfoque en gamificación** • **Implementación más técnica**	
Contexto ideal	SOC maduros que quieren integrar el usuario como sensor activo.

2.5 Phished

Plataforma europea basada en IA.	
Fortalezas: • **Modelo adaptativo individual** • **Risk scoring dinámico** • **Enfoque científico en comportamiento**	
Limitaciones: • **Menor presencia global que KnowBe4** • **Ecosistema más pequeño**	
Contexto ideal	Empresas medianas con enfoque en personalización.

2.6 NINJIO

Modelo basado en storytelling tipo serie animada.	
Fortalezas: • **Alto engagement** • **Microlearning narrativo** • **Fácil adopción**	
Limitaciones: • **Menor profundidad técnica en simulaciones** • **Más awareness que simulación avanzada**	
Contexto ideal	Organizaciones que priorizan cultura sobre métricas técnicas profundas.

2.7 Mimecast

Mimecast integra awareness dentro de su suite de seguridad de correo.	
Fortalezas: • **Integración nativa con su email security** • **Métricas integradas de threat landscape**	
Limitaciones: • **Menor personalización adaptativa** • **Dependencia del ecosistema Mimecast**	
Contexto ideal	Clientes actuales de Mimecast

2.8 Infosec IQ

Plataforma orientada a compliance y formación estructurada.	
Fortalezas: • **Amplio catálogo formativo** • **Métricas claras de desempeño** • **Fuerte enfoque en normativas**	
Limitaciones: • **Simulación menos sofisticada que Hoxhunt o Phished** • **Menor componente IA adaptativa**	
Contexto ideal	Organizaciones con fuerte presión regulatoria.

3. Tabla técnica comparativa

Criterio	Hoxhunt	Proofpoint	KnowBe4	Cofense	Phished	NINJIO	Mimecast	Infosec IQ
IA adaptativa	Alta	Media	Media	Baja	Alta	Baja	Media	Baja
Human Risk Score	Sí	Sí	Sí	Parcial	Sí	No	Parcial	Sí
Gamificación	Alta	Baja	Media	Baja	Media	Alta	Baja	Baja
Integración con email gateway	Media	Alta	Media	Alta	Media	Baja	Alta	Media
Enfoque en reporting rate	Muy alto	Alto	Alto	Muy alto	Alto	Medio	Alto	Medio
Microlearning inmediato	Sí	Sí	Sí	Sí	Sí	Sí	Sí	Sí
Analítica avanzada	Alta	Alta	Alta	Alta	Alta	Media	Alta	Media
Orientación compliance	Media	Alta	Muy alta	Alta	Media	Media	Alta	Muy alta
Control ético	Alto	Alto	Medio	Alto	Alto	Alto	Alto	Medio

4. Análisis crítico comparativo

Desde una perspectiva técnica y ética, se pueden identificar tres grandes grupos:

Grupo 1 – IA Adaptativa Avanzada

- Hoxhunt
- Phished

Enfoque centrado en transformación conductual real.

Grupo 2 – Integración empresarial y compliance

- Proofpoint
- Mimecast
- KnowBe4
- Infosec IQ

Fuertes en regulación y escalabilidad corporativa.

Grupo 3 – Cultura y engagement

- NINJIO
- Cofense

Ventajas comparativas

- Hoxhunt lidera en personalización conductual.
- KnowBe4 domina en contenido y compliance.
- Proofpoint y Mimecast destacan en integración técnica.
- Cofense sobresale en modelo SOC-human integration.

Limitaciones generales del mercado

- Riesgo de fatiga del usuario.
- Dependencia excesiva del click rate como métrica primaria.
- Posible percepción de vigilancia si no hay política ética clara.

5. Consideraciones éticas en la simulación de phishing

Un programa ético debe:

- Evitar humillación pública.
- No utilizar simulaciones traumáticas (ej. falsas muertes).
- Garantizar transparencia organizacional.
- Priorizar aprendizaje sobre castigo.

Las plataformas más maduras integran principios de:

- Refuerzo positivo.
- Entrenamiento inmediato.
- Cultura de seguridad psicológica.

6. Conclusión comparativa

Después del análisis técnico, se puede concluir que no existe una "mejor plataforma universal", sino soluciones alineadas a distintos niveles de madurez organizacional.

Si el objetivo es transformación conductual avanzada	Hoxhunt o Phished.
Si el objetivo es cumplimiento normativo y escalabilidad	KnowBe4 o Infosec IQ.
Si la organización ya tiene infraestructura consolidada	Proofpoint o Mimecast.
Si se busca fortalecer el SOC y el modelo de reporte	Cofense.
Si el foco es engagement cultural	NINJIO.

Desde una perspectiva estratégica, las plataformas que combinan IA adaptativa con métricas de reporting y control ético son las que marcan la evolución del mercado.

7. Referencias

- *KnowBe4. (2023). Security awareness training report. https://cybersecurityventures.com/wp-content/uploads/2023/04/Security-Awareness-Training-Report-2023-1.pdf*

- *Proofpoint. (2023). State of the Phish report. https://go.proofpoint.com/2023-State-of-the-Phish-Report.html*

- *Hoxhunt. (2023). Human risk management whitepaper. https://www.researchgate.net/publication/396775632_Human_Risk_Management_Turning_Employees_into_Cybersecurity_Assets*

- *Cofense. (2023). Phishing defense center overview. https://cofense.com/blog/2023-cofense-phishing-intelligence-trends-review-q2/*

- *Mimecast. (2023). Email security and awareness report. https://www.mimecast.com/resources/ebooks/the-state-of-email-security-2023/*

- *Infosec IQ. (2023). Security awareness program guide. https://www.infosecinstitute.com/resources/security-awareness/ultimate-guide/*

- *Verizon. (2023). Data breach investigations report (DBIR). https://www.verizon.com/business/resources/Ta5a/reports/2023-dbir-public-sector-snapshot.pdf*